

Sigma

SIEM Detection Format

Detection Engineering with Sigma

2025-10-21

Thomas Patzke

Agenda



1. Introduction into Sigma
2. Writing rules for single events
3. Writing correlation rules for matching on event relationships.
4. Best practices in rule writing

Hands-on:

- A text editor with YAML support.
  - Recommendation: VSCode with Sigma extension.
- A conversion tool
  - Sigma CLI
  - Sigconverter.io (integrated within VSCode Sigma extension)
- A clone of the workshop repository.

https://github.com/thomaspatzke/detection-engineering-with-sigma



Why Using Sigma Rules?



- Not reinventing things: repository of 2k+ existing open source rules, steadily growing.
- Write-once, use many times: many organizations don’t have a single target system but various (SIEM, EDR, data lake, migrations, M&A …)
- Reduce vendor lockin: switch your SIEM just by changing the conversion configuration instead of migrating every single detection.
- Share generic detection logic instead of vendor-specific queries.

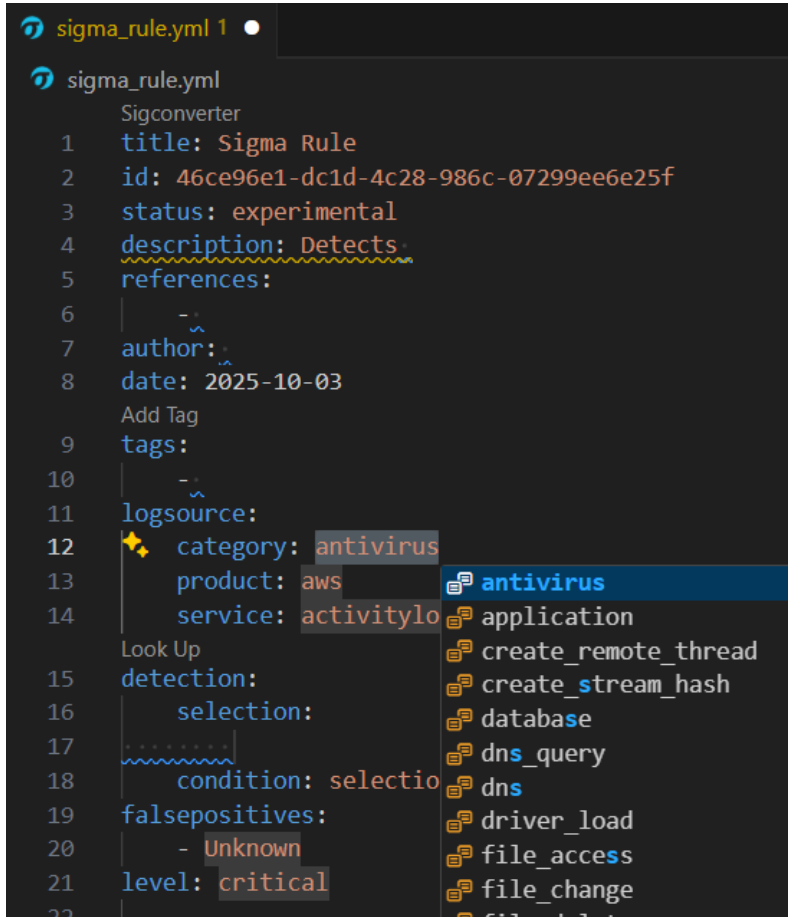
Sigma Goals and Scope



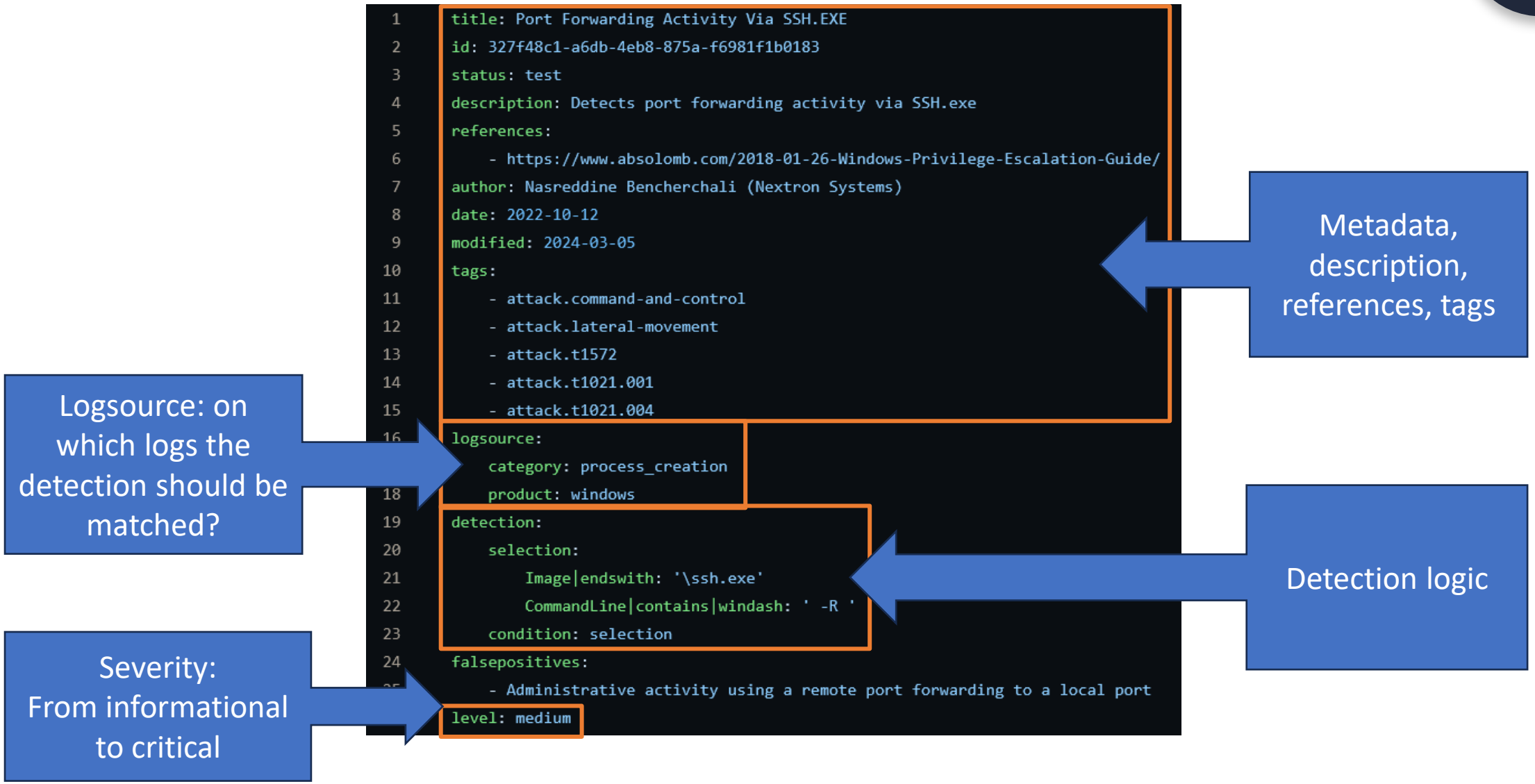
- Rules should be easily writable.
- Human-readable actionable rules.
- Machine-readable: toolchain for conversion into queries or SIEM/EDR rules.
- Simple: expressiveness for 95% of detections, not every imaginable use case.
- Generic: detections written in Sigma should be convertible into most target languages.
- Shareable

Sigma VSCode Extension

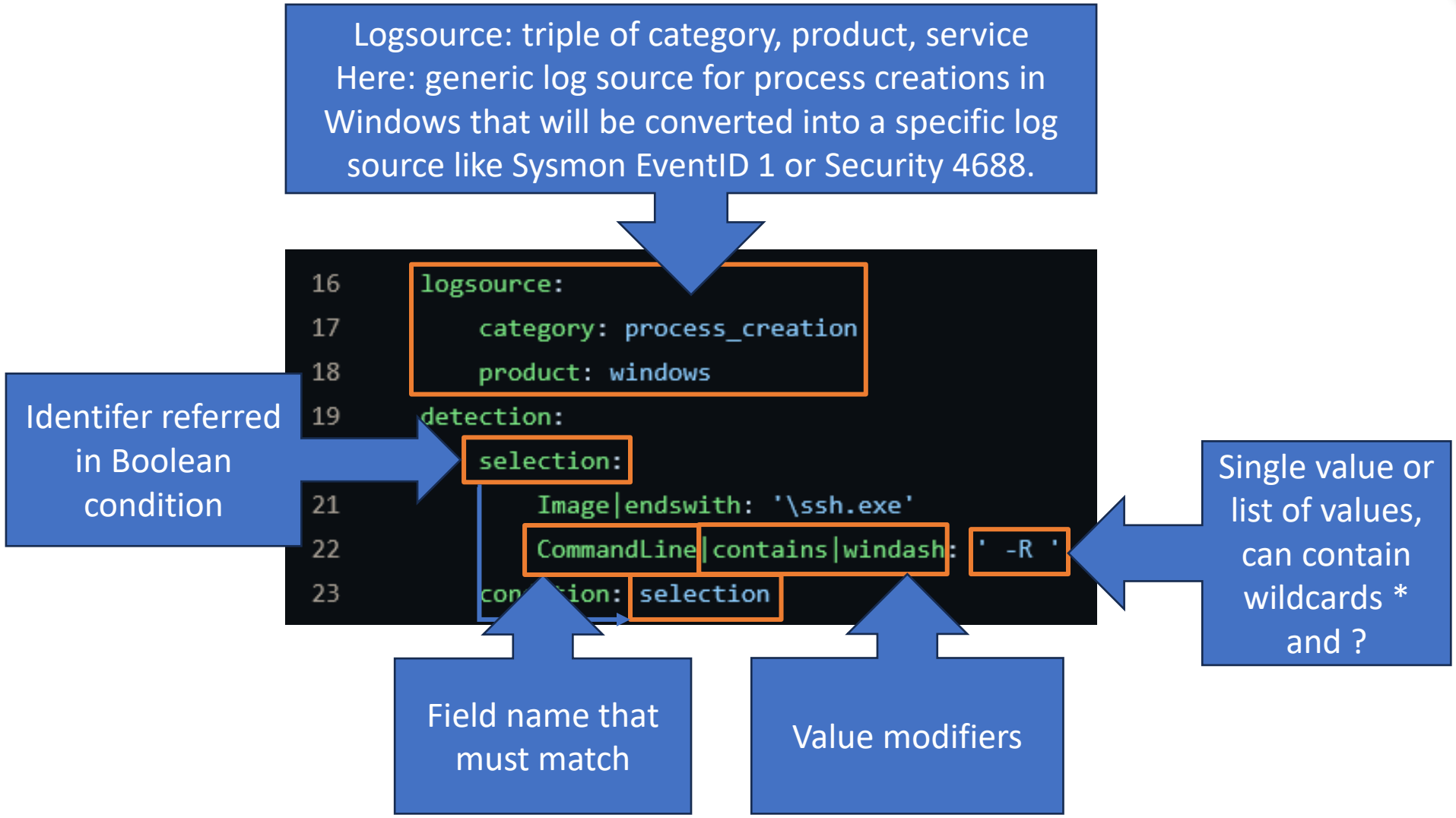
- Sigma rule template
- Autocompletion
- Conversion with sigconverter.io directly from VSCode.



Anatomy of a Sigma Rule



Logsource & Detection

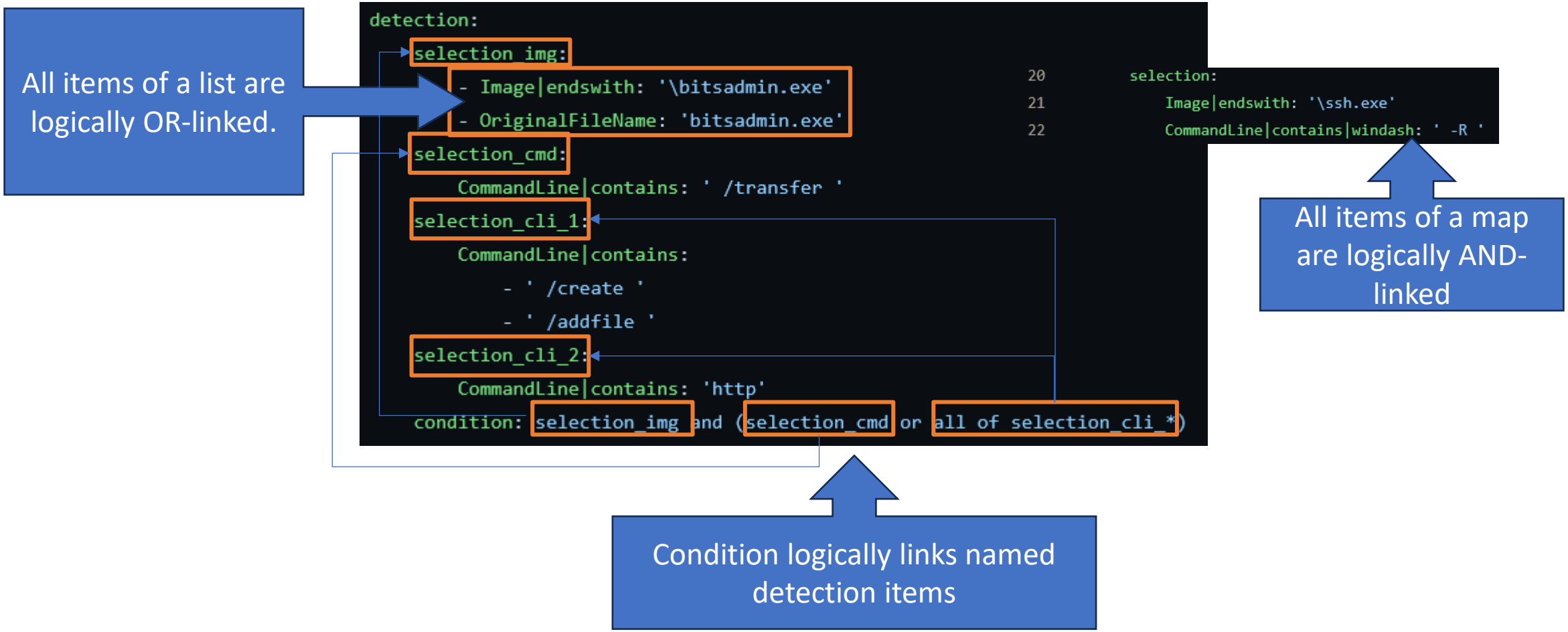


Value Modifiers



Modifier	Purpose
startswith/endswith/contains	Value starts, ends or contains the given value (instead of *value*)
re	Match value as regular expression.
cidr	Match value as CIDR network range (e.g. 10.0.0.0/8)
base64	Match given value Base64-encoded as whole.
base64offset|contains	Match given value as part of base64 encoded string.
wide/utf16/utf16le	Convert to given encoding.
windash	Expand parameter dashes “–” into all forms that are also valid like /.
gt/gte/lt/lte	>, >=, <, <= on numerical values (e.g. HTTP status codes)
exists	Check for field existence, value is yes or no.
expand	Expand %placeholders% as configured in processing pipelines.
fieldref	Reference another field for comparison
all	AND-link list elements instead of default OR-linking.

Logic & Condition



Rule Conventions



- File name should be <log_source>_<short detection title>.yml, e.g.
  - win_security_susp_add_sid_history.yml
  - proc_creation_win_rundll32_uncommon_dll_extension.yml
  - proc_creation_win_susp_double_extension.yml
- Rule attributes should have an order, typically they start with the metadata followed by the detection logic and closing with false positives and level.

Best Practices



- Avoid keyword rules, always try to match named fields.
- Avoid regular expressions, they are less performant in many SIEMs.
- Try to put wildcards at token-boundaries: `*\path\*` has usually a much better performance as `*path*`.
- Use modifiers instead of wildcards.
- Double escape backslashes in double quote YAML context or generally.
- Avoid complexity! Rule of thumb: additional complexity in detection rules should provide value (often less false positives). Examples:
  - Add only conditions if they reduce false positives.
  - Write only correlation rules if detecting the single event is not sufficient

Exercise 1: Failed Logon



- Write a Sigma rule that detects failed logon attempts in Windows security logs.
- Some hints:
  - The Windows EventID is 4625
  - MITRE ATT&CK technique T1110.001 (Brute Force: Password Guessing) fits quite well.

Exercise 2:
Write a Sigma Rule for PRT Token Theft



- Process creation of BrowserCore.exe
- Only allow the following parent images:
  - cmd.exe
  - Teams.exe
- Only allow invocation that contain a specific Chrome plugin: chrome-extension://ppnbnpeolgkicgegkbkbjmhlideopiji/
- MITRE ATT&CK techniques are T1003, T1134.001

Sigma Correlation Rules

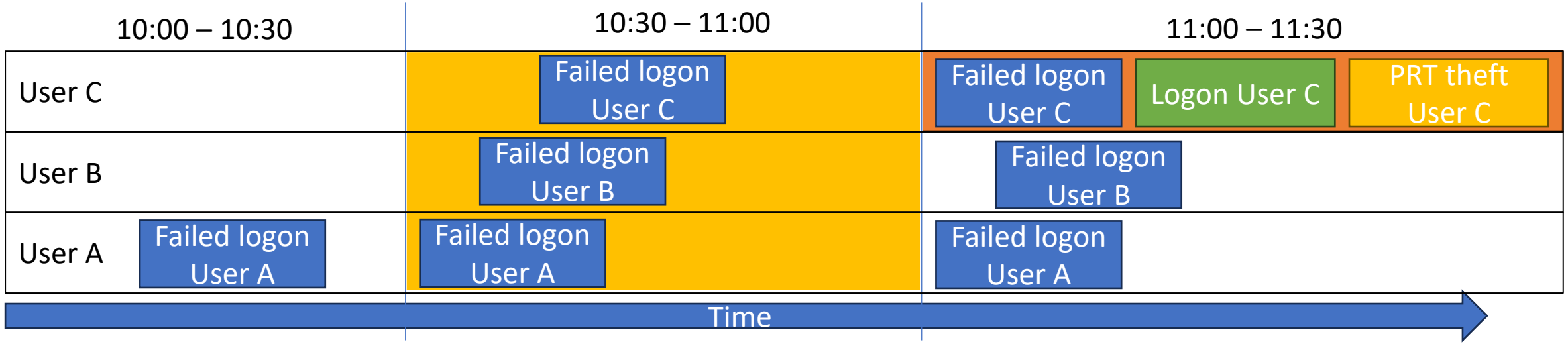


- Sigma rules match on *single events* that match the defined conditions.
- Some detections need further logic that takes the context of such single events into account.
- Example: brute force or password spraying attacks are characterized by multiple attempts for guessing a password.
- Sigma correlation rules provide a framework to express such relationships between single events in a generic way.

Correlation Concepts



- A correlation rule matches on *base events* of different *event types*.
- Correlation rules detect across a given *time frame*.
- Single events can be *grouped* by commonalities, e.g. they appear for the same user.
- Time frame and grouping define a *correlation scope*.
- The *correlation condition* defines how the events must appear within the correlation scope to trigger the detection.
- There are different *correlation types*.

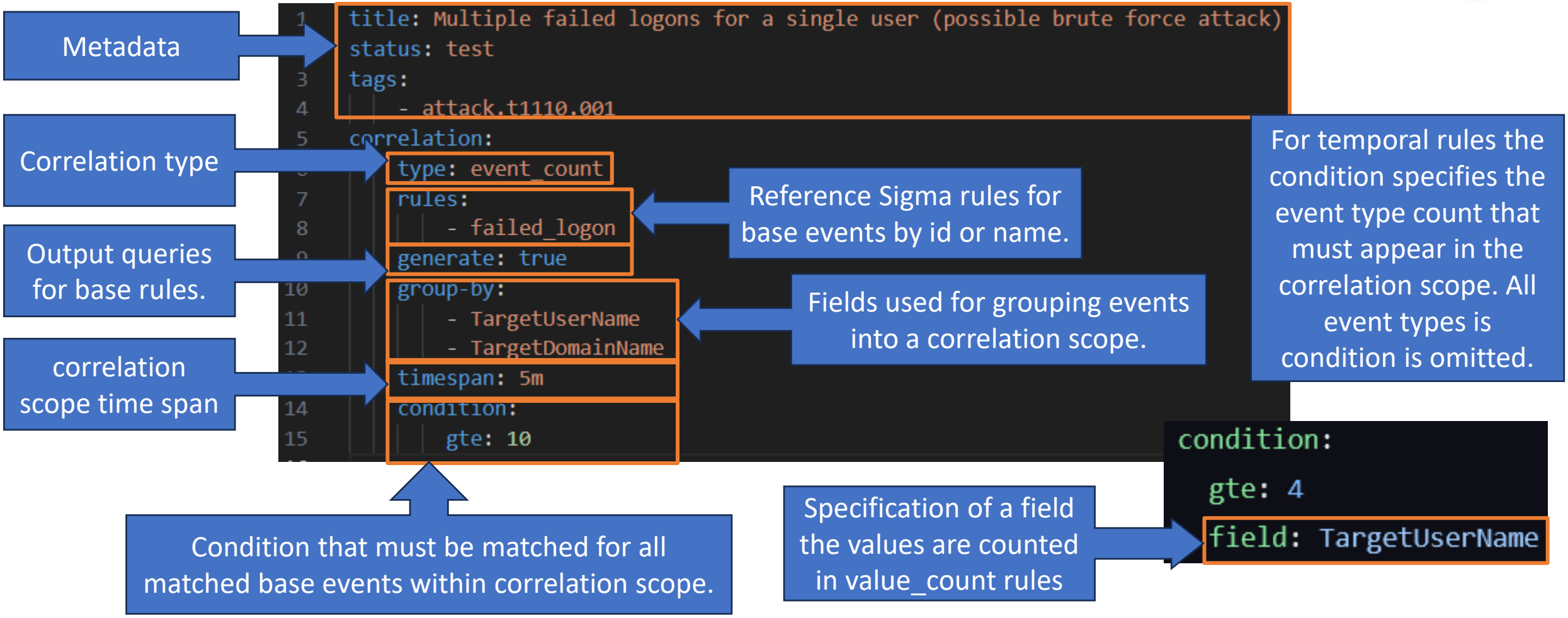


Correlation Types



Type	Description
event_count	Event count matches a condition in the correlation scope. Example: 10 failed logons for a user in 10 minutes = brute force attempt
value_count	Within a given correlation scope the count of different values for a given field matches a condition. Example: Failed logons for 10 different users by the same source IP = password spray
temporal	Within the correlation scope events of different type are observed with at least the given count of types. Example: failed and successful logon and a PRT token theft by the same user
ordered_temporal	Like temporal, but the event types furthermore appear in the given order.

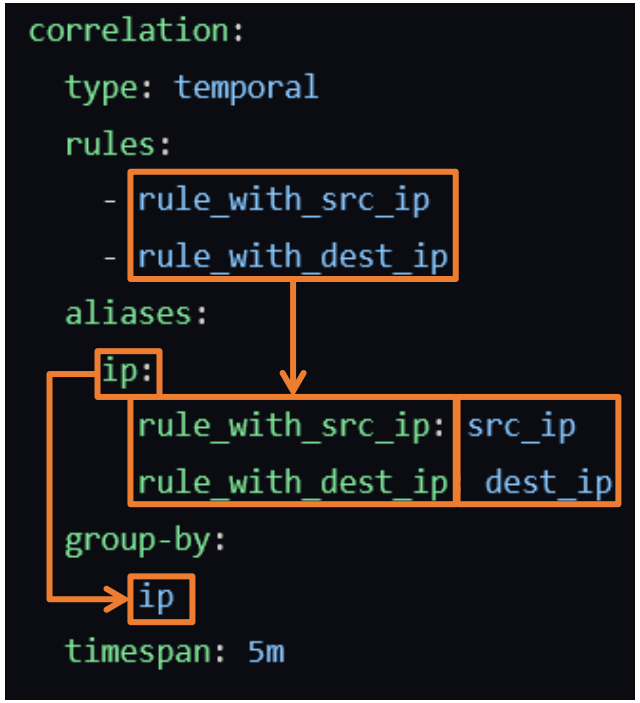
Anatomy of a Sigma Correlation Rule



Field Aliases



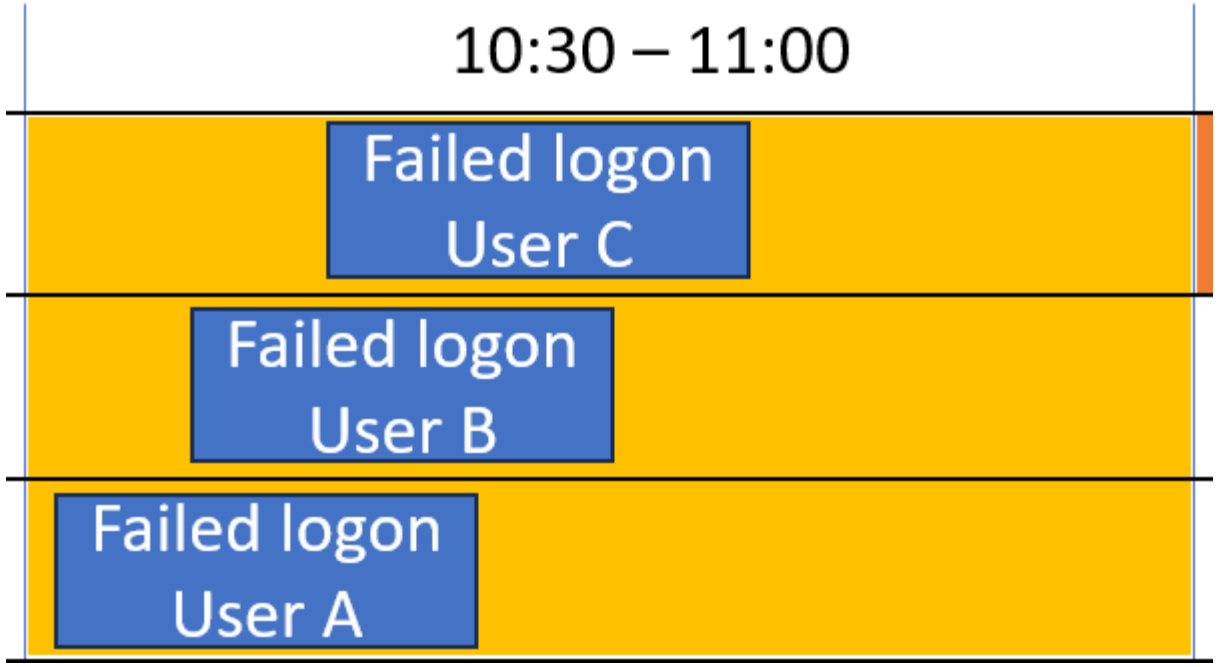
- Problem: grouping of values across different fields.
- Example: Source IP of event matched by rule A is destination IP of event matched by rule B.
- Fields aliases define a *virtual field* by mapping of rules to field names in the matched events.



Exercise 3:
Write a Password Spraying Rule



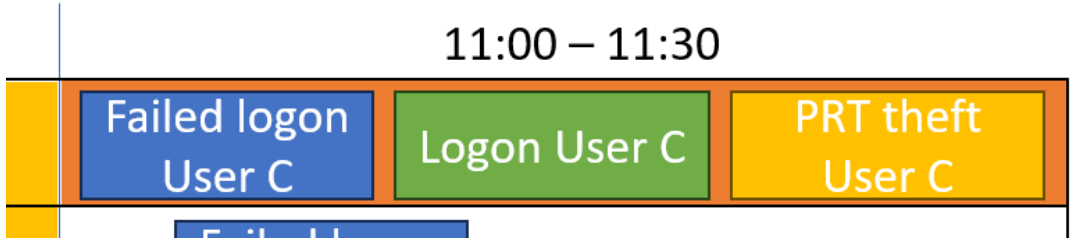
- Password spraying = trying passwords across many users (from single source)
- The source IP is located in the field IpAddress



Exercise 4:
Write a Temporal Correlation Rule



- The rule should match on the following events:
  - Failed logon
  - Successful logon
  - PRT theft
- For a single user
  - For successful and failed logons it's contained in TargetUserName.
  - For the process creation in User.
- Two event types are sufficient.



Recap & Outlook

- In this workshop we learned…
  - Writing Sigma rules for single events.
  - Writing Sigma correlation rules
- Another topic: operationalization
  - Conversion
  - Adapting to environment
  - CI/CD



Sigma operationalization workshop

Further Trainings



Writing and converting Sigma rules:

Applied Network Defense: Detection Engineering with Sigma

- https://www.networkdefense.co/courses/sigma/



Building a detection pipeline with Sigma:

Taggart Institute: Automated Detection with Sigma

- https://taggartinstitute.org/p/detection-with-sigma



Further Resources



- SigmaHQ (sigmahq.io)
- SigmaHQ Discord
- SigmaHQ GitHub
- thomas@patzke.org

SigmaHQ

Discord

Rule Repository

Sponsoring